

Security incident report

Section 1: Identify the network protocol involved in the incident

The network protocol involved in this incident is the Hypertext Transfer Protocol (HTTP). The tcpdump traffic log shows HTTP GET requests being sent to both yummyrecipesforme.com and greatrecipesforme.com over port 80. After the DNS server resolved the domain names to their corresponding IP addresses, the browser established HTTP connections to the websites. The malicious file was delivered to users through an HTTP connection, and the subsequent redirection to the malicious website also occurred using HTTP.

Section 2: Document the incident

Several customers reported to the yummyrecipesforme.com helpdesk that the website prompted them to download and run a file claiming to provide access to free recipes. After executing the file, customers observed that their computers became slower and that they were redirected to a different website. Additionally, the website owner was unable to access the administrator account and contacted the web hosting provider for assistance.

To investigate the incident, a cybersecurity analyst created a sandbox environment and used tcpdump to capture network traffic while visiting yummyrecipesforme.com. During testing, the website prompted the analyst to download an executable file disguised as a browser update. After the file was executed, the browser redirected to greatrecipesforme.com.

Analysis of the tcpdump log showed that the browser first sent a DNS request to obtain the IP address for yummyrecipesforme.com. After receiving the IP address, the browser established an HTTP connection and requested the webpage. The browser then downloaded the malicious executable file. Shortly

afterward, the browser generated a second DNS request for greatrecipesforme.com and received a corresponding IP address. The browser then established another HTTP connection to greatrecipesforme.com, where the malicious content was hosted.

Further investigation by a senior cybersecurity analyst revealed that the website had been compromised through a brute force attack. The attacker successfully guessed the administrator account's default password and gained access to the website's administrative panel. The attacker modified the website's source code by embedding malicious JavaScript that prompted visitors to download an executable file. Analysis of the downloaded file confirmed that it redirected users from yummyrecipesforme.com to greatrecipesforme.com. After gaining access, the attacker changed the administrator password, preventing the website owner from accessing the account.

Sources of evidence:

- Customer complaints submitted to the helpdesk
- tcpdump network traffic logs
- Sandbox testing results
- Website source code analysis
- Malware analysis of the downloaded executable file

Section 3: Recommend one remediation for brute force attacks

One effective security measure to prevent brute force attacks is to enforce two-factor authentication (2FA) for administrator accounts. With 2FA enabled, users must provide both their password and a second authentication factor, such as a one-time passcode sent to a mobile device or email address. Even if an attacker successfully guesses a password, they would still be unable to access the account without the second authentication factor. Implementing 2FA significantly reduces the likelihood of unauthorized access and helps protect administrative accounts from brute force attacks.

